

Vulnerability Scan Remediation

Purpose

This document provides a comprehensive scan and remediation procedure designed to help protect the systems managed at the CSU Fullerton.

Information Security Office (ISO) staff will identify potential threats and vulnerabilities through internal and external scans periodically. Thereafter, Sys-Admins (Responsible Parties) will be provided the scan results for remediation. The work to maintain a secure infrastructure environment is a collaborative effort between ISO, IT application teams, and Infrastructure Services staff by supervision of the management.

1.0 Scope

The scope of this procedure includes:

- The type and schedule of scans to be run
- Review and remediation of findings from scan reports
- Responsibilities of positions that will perform tasks

2.0 Definitions

Acceptable risk – Vulnerabilities identified in the scan but compensating controls are in place to mitigate the risk, or the service has been deemed critical and risk is accepted and approved.

Acceptable risk exceptions – Vulnerabilities that are recognized and it is determined that the risk is so low that it accepted and no further action is needed; or the financial cost of remediation is so great that it is not feasible to make changes to alleviate the vulnerability.

Data Owner – Management staff who approve access and changes to information/data of an application.

Data Steward – The individuals who make up the application teams and have the best ability to verify vulnerabilities and make recommendations for remediation.

False-positive – Vulnerabilities identified in the scan that are not vulnerabilities and do not cause a threat to the CSUF systems.

3.0 Responsibilities

Information Security Team – The basic role of the security team is to configure the scanning tool, run scans, prepare, review, and disseminate reports, and provide assistance.

Application Management – Management staff who are responsible for assigning individuals to review the scan report approve remediation and provide documentation to determine acceptable risk.

Application Teams/Infrastructure Services – Staff will review potential vulnerabilities and implement remediation recommendations. As appropriate, staff may take steps to reclassify, provide documentation and business justification to demonstrate vulnerability as false-positive or an acceptable risk.

Infrastructure Services – In addition to remediation responsibilities, Infrastructure Services staff will complete monthly patching according to the established schedule.

4.0 Procedures

Step 0 – Request access to Qualys Scanner

If you plan on using the WAS in your remediation efforts, you must first request access from the Information Security Team. Please email soc@fullerton.edu to request an account and schedule training on how to scan your web applications for any vulnerabilities. The scan reports will include detailed steps to remediate any vulnerabilities.

Step 1 - Run Scans and Prioritize Findings

ISO staff will run scans, according to the scan schedule and create reports. The reports list vulnerabilities as critical, severe, and moderate. Vulnerabilities should be addressed as a priority with focus on Critical and severe, moderate vulnerabilities as time is available. PCI requirements calls for remediating Critical and Severe vulnerabilities in 30 days. Ideally, all vulnerabilities should be addressed; however, ISO staff will work with application teams on the most significant first.

Below is the scan schedule:

Application Team	IP addresses	Scan time	Number of hosts
ASC	Refer to CDE document xyz		
ASI			
UEE			

Step 2 – Review and Distribution of Reports

After reports are produced, ISO staff will provide a first level review of scans for critical vulnerabilities that affect servers with Level 1 data. Thereafter, the ISO will meet with application teams to discuss the results and provide assistance or an explanation of the findings.

ISO staff will also distribute the link to scan reports via email to application teams and Infrastructure Services staff.

Step 3 - Apply Patches

Patches are applied monthly as follows:

- Infrastructure Services staff will identify needed patches and submit a change request (CR) for approval.
- Infrastructure Services staff will install patches in the development and test environments on the Thursday following the release of Microsoft patches.
- Patches to the production environment will be installed on the following Sunday at 12:00 a.m.

5.0 Unresolved Issues and Vulnerabilities

Identified vulnerabilities should be remediated in a timely manner based on their severity and risk to the campus environment. The following remediation timelines are used as general guidance:

Severity	Remediation Time
Critical	7-15 days
High	30 days

If a vulnerability cannot be resolved through the normal patching process within 30 days, the Information Security Office (ISO) will work with the system owner to identify and implement appropriate mitigation measures to reduce the associated risk.

Examples of alternative mitigation controls may include.

- Applying compensating security controls (e.g., firewall restrictions, network segmentation, access control policies).
- Disabling or removing vulnerable services or software components.
- Implementing configuration hardening or application-level protections.
- Monitoring the system for suspicious activity until remediation becomes available

The vulnerability will continue to appear in vulnerability scan reports until it is fully remediated.

If the vulnerability cannot be remediated due to operational, technical, or vendor limitations, the system or data owner may request a risk exception.

The risk exception process includes the following steps:

1. The **data steward or system owner** documents the business justification and risk acceptance using the **Security Risk Business Justification Form**.
2. The justification must describe.
 - the affected system
 - the vulnerability details
 - why remediation is not currently feasible
 - compensating controls implemented
 - the expected timeline for remediation (if applicable)

3. The request is submitted to the Department Manager of the System Owner for approval.
4. The request is submitted to the **Information Security Office (ISO)** for review and approval.
5. The **Chief Information Officer (CIO)** reviews the Business Risk Justification form submission for associated risk.

Approved exceptions are documented and periodically reviewed until the vulnerability is resolved or the exception expires.

6.0 References and Information

Appendix A – Security Risk Business Justification Form